



◆ OFFENSIVE SECURITY SERIES ◆

FFUF

Directory, File, VHost, Parameter & API Endpoint Fuzzing

Directory · Extension · VHost · POST Param · API · Filter · Auto-calibrate

Dir Fuzz

Extension Fuzz

VHost Fuzz

POST Param

API Fuzz

Auto-calibrate

Rate Limit

RedTeamGarage (RTG) | Offensive Security Education

<https://www.redteamgarage.com/>

LEGAL DISCLAIMER

This guide is produced by RedTeamGarage (RTG) for educational purposes only. All techniques must ONLY be used on systems you own or have explicit written authorisation to test. RTG assumes zero liability for any misuse of this material.

**TABLE OF CONTENTS**

FFUF — Directory, File, VHost, Parameter & API Endpoint Fuzzing

01.	FFUF OVERVIEW & DIRECTORY FUZZING
02.	EXTENSION & BACKUP FILE DISCOVERY
03.	VHOST FUZZING & POST PARAMETERS
04.	FFUF CHEAT SHEET



01 — DIR FUZZING

Directory & File Discovery

ffuf (Fuzz Faster U Fool) is an ultra-fast web fuzzer written in Go. It fuzzes directories, files, parameters, headers, virtual hosts, and API endpoints. Its speed (thousands of req/sec) and powerful filtering make it the preferred tool for web enumeration.

```
ffuf - Directory & File Fuzzing

# Install ffuf
(kali)-[~]
kali $ sudo apt install ffuf
Setting up ffuf (2.1.0) ...

(kali)-[~]
kali $ ffuf --version
ffuf version 2.1.0 (Changelog: https://github.com/ffuf/ffuf/blob/master/CHANGELOG.md)

# Basic directory/file fuzzing
(kali)-[~]
kali $ ffuf -u http://10.10.10.100/FUZZ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -m
c 200,204,301,302,307,401,403

/
| | / _|
/ _| | _|
| | | _|
| | | _|
\_| | _| v2.1.0

[Status: 200, Size: 12043, Words: 987, Lines: 203, Duration: 12ms]
* FUZZ: index.php
[Status: 301, Size: 315, Words: 20, Lines: 10, Duration: 8ms]
* FUZZ: admin
[Status: 200, Size: 4892, Words: 234, Lines: 89, Duration: 15ms]
* FUZZ: login
[Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 9ms]
* FUZZ: .htaccess

:: Progress: [220560/220560] :: Job [1/1] :: 8234 req/sec :: Duration: [0:00:27]
```

Figure: ffuf finds /admin (301), /login (200), /.htaccess (403) in 27 seconds at 8234 req/s



02 — EXTENSION FUZZING

Backup File Discovery

```
ffuf - Extension Fuzzing & Backup Discovery

# Fuzzing with smart auto-calibration (filter similar responses)
(kali)-[~]
kali $ ffuf -u http://10.10.10.100/FUZZ -w /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt -ac
      -o results.json
[Status: 200, Size: 12043] admin/index.php
[Status: 200, Size: 8931] uploads/
[Status: 200, Size: 2341] config/
:: Progress: [30000/30000] :: 12345 req/sec :: Duration: [0:00:02]

# Extension fuzzing - find PHP, ASP, ASPX files
(kali)-[~]
kali $ ffuf -u http://10.10.10.100/admin/FUZZ -w /usr/share/seclists/Discovery/Web-Content/raft-medium-words.txt -e .
      php,.aspx,.txt,.bak -mc 200,301 -fc 404
[Status: 200, Size: 4892] login.php
[Status: 200, Size: 892] config.php.bak - backup file!
[Status: 200, Size: 2341] dashboard.php

# Download config backup - may contain credentials
(kali)-[~]
kali $ curl http://10.10.10.100/admin/config.php.bak
<?php
define("DB_HOST", "localhost");
define("DB_USER", "webapp_admin");
define("DB_PASS", "Sup3rS3cr3tPwD!");
define("DB_NAME", "webapp_db");
define("SECRET_KEY", "jwt_secret_key_2024_do_not_share");
```

Figure: config.php.bak found and downloaded — database credentials and JWT secret exposed



03 — VHOST & POST FUZZ

Subdomain & Parameter Discovery

```
ffuf - VHost Fuzzing & POST Parameter Discovery

# Virtual host (vhost) fuzzing - find subdomains
(kali)-[~]
kali $ ffuf -u http://10.10.10.100/ -H 'Host: FUZZ.target.htb' -w /usr/share/seclists/Discovery/DNS/subdomains-top1mi
llion-5000.txt -fs 612
[Status: 200, Size: 17234, Words: 3421] dev
[Status: 200, Size: 8923, Words: 1234] admin
[Status: 200, Size: 4521, Words: 876] api

# Add vhosts to /etc/hosts
(kali)-[~]
kali $ echo "10.10.10.100 dev.target.htb admin.target.htb api.target.htb" >> /etc/hosts

# POST parameter fuzzing (find hidden params)
(kali)-[~]
kali $ ffuf -u http://10.10.10.100/login -X POST -d 'username=FUZZ&password=test' -w users.txt -mr 'Welcome'
[Status: 302, Size: 0, Words: 0, Duration: 45ms]
* FUZZ: administrator - VALID USERNAME!

# API endpoint fuzzing
(kali)-[~]
kali $ ffuf -u http://10.10.10.100/api/v1/FUZZ -w /usr/share/seclists/Discovery/Web-Content/api-endpoints.txt -mc 200
,201 -H 'Authorization: Bearer TOKEN'
[Status: 200] users
[Status: 200] admin
[Status: 201] upload
```

Figure: 3 vhosts discovered, hidden admin vhost found, POST fuzzing finds valid admin username



04 — FFUF CHEAT SHEET

Quick Reference

Basic dir fuzz	<code>ffuf -u http://TARGET/FUZZ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -mc 200,301,302,401,403</code>
Auto-calibrate	<code>ffuf -u http://TARGET/FUZZ -w wordlist.txt -ac</code>
Extension fuzz	<code>ffuf -u http://TARGET/FUZZ -w wordlist.txt -e .php,.aspx,.txt,.bak,.config</code>
Filter by size	<code>ffuf ... -fs SIZE (filter out this response size)</code>
Filter by words	<code>ffuf ... -fw WORDS</code>
Match by regex	<code>ffuf ... -mr "Welcome Dashboard success"</code>
VHost fuzzing	<code>ffuf -u http://TARGET/ -H "Host: FUZZ.target.htb" -w subdomains.txt -fs DEFAULT_SIZE</code>
POST param fuzz	<code>ffuf -u http://TARGET/login -X POST -d "u=FUZZ&p=test" -w users.txt</code>
GET param fuzz	<code>ffuf -u "http://TARGET/page?id=FUZZ" -w numbers.txt -mc 200</code>
Header fuzz	<code>ffuf -u http://TARGET/ -H "X-Custom-Header: FUZZ" -w wordlist.txt</code>
API fuzz	<code>ffuf -u http://TARGET/api/v1/FUZZ -w api-endpoints.txt -H "Authorization: Bearer TOKEN"</code>
Rate limit	<code>ffuf ... -rate 50 (max 50 req/sec)</code>
Output JSON	<code>ffuf ... -o results.json -of json</code>
Threads	<code>ffuf ... -t 50 (default 40)</code>
Recursion	<code>ffuf ... -recursion -recursion-depth 2</code>



CONNECT WITH REDTEAMGARAGE (RTG)

The Community. The Knowledge. The Edge.



Official Website	https://www.redteamgarage.com/
Telegram	https://t.me/redteamgarage
LinkedIn	https://www.linkedin.com/company/redteamgarage-rtg

RTG MISSION

Real-world offensive security training - practical, no fluff, built for serious learners.

Build the most comprehensive red team technique library available anywhere.

Train the next generation of elite offensive security professionals globally.

© RedTeamGarage (RTG). All content for educational and authorized security testing only.